

LAB GUIDELINES

Lab 9 — Server Firewall and Port Management

Maps to CompTIA Server+ objective **2.2** — Firewall, Ports.

Run all commands on <https://killercode.com/playgrounds/scenario/ubuntu>

Required software (free, apt): ufw, nftables, nginx, nmap

```
apt update && apt install -y ufw nftables nginx nmap
```

Step 1 — Memorise the well-known server ports

Port	Protocol	Service
20/21	TCP	FTP (data / control)
22	TCP	SSH / SFTP / SCP
23	TCP	Telnet (disable!)
25	TCP	SMTP
53	TCP/UDP	DNS
67/68	UDP	DHCP server / client
80	TCP	HTTP
88	TCP/UDP	Kerberos
110	TCP	POP3
123	UDP	NTP
135-139, 445	TCP	SMB / CIFS / NetBIOS
143	TCP	IMAP
161/162	UDP	SNMP / SNMP trap
389	TCP	LDAP
443	TCP	HTTPS
636	TCP	LDAPS
989/990	TCP	FTPS
993/995	TCP	IMAPS / POP3S
1433	TCP	Microsoft SQL Server
1521	TCP	Oracle DB
3306	TCP	MySQL / MariaDB
3389	TCP	RDP
5432	TCP	PostgreSQL

Step 2 — Start a service, observe its open port

```
systemctl start nginx
ss -tlnp | grep nginx
nmap -p80 127.0.0.1
```

Step 3 — UFW (uncomplicated firewall) — the friendly front-end

```
uFW --force reset
uFW default deny incoming
uFW default allow outgoing
uFW allow 22/tcp comment 'SSH admin'
uFW allow 80/tcp comment 'HTTP'
uFW allow 443/tcp comment 'HTTPS'
uFW --force enable
uFW status verbose
```

Step 4 — Confirm the policy is effective

```
apt install nmap
nmap -p 22,23,25,80,443,3306 127.0.0.1
```

22, 80, 443 → open. 23, 25, 3306 → filtered/closed.

Step 5 — Same rules in raw `nftables`

UFW is a wrapper; the underlying engine is nftables. Inspect and write a rule directly:

```
nft list ruleset | head -40
nft add table inet filter
nft add chain inet filter input '{ type filter hook input priority 0; policy accept; }'
nft add rule inet filter input tcp dport 8080 accept
```

Step 6 — Source-restricted (RBAC-style) rules

Allow MySQL only from one subnet:

```
uFW allow from 10.99.99.0/24 to any port 3306 proto tcp comment 'MySQL app tier'
uFW status numbered
```

The principle: **deny everything, then allow only the minimum from the minimum sources**. This is the "close unneeded ports" requirement from objective 3.5 as well.

Step 7 — Auditing open vs. listening

```
ss -tulnp # what is *listening* on this host
nmap -sT 127.0.0.1 # what an attacker would see locally
uFW status numbered # what the firewall permits
```

Three views; all three must agree, or you have a gap.

Step 8 — Logging firewall drops

```
uFW logging medium
grep UFW /var/log/syslog | tail || journalctl -k | grep UFW | tail
```

Feed these logs into the SIEM lab (Lab 22) for alerting on repeated probes.

Free online tools

- ****IANA service name / port registry**** — <https://www.iana.org/assignments/service-names-port-numbers/>
- ****nftables wiki**** — <https://wiki.nftables.org/>
- ****UFW manual**** — <https://help.ubuntu.com/community/UFW>

What you learned

- The Server+ well-known port table you must memorise.
- `uFW` default-deny + explicit allow workflow.
- Translating UFW rules to the underlying nftables ruleset.

- Source-restricted firewall rules (cidr → port).
- The 3-view audit: `ss` listening, `nmap` reachable, `ufw status` permitted.